Methods and Principles of Designing Modern Secure Systems

Practice 3

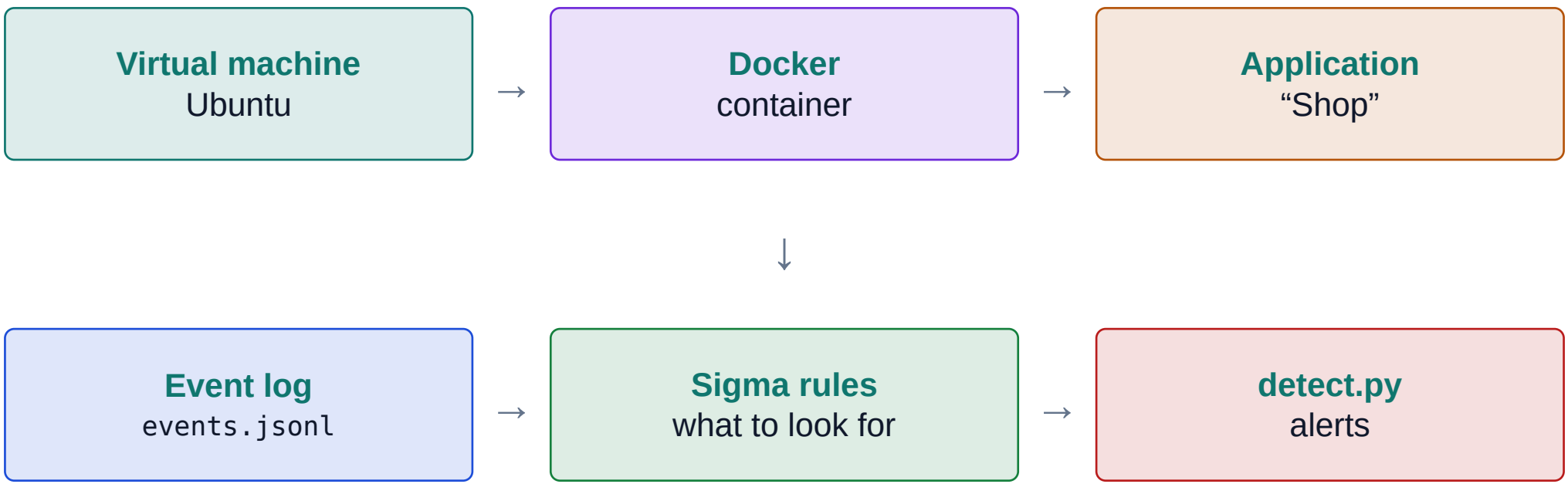
Detecting Attacks from the Event Log

Interactive practice · a browser attack, a live log, Sigma rules

What we will do in this session

1. Create an Ubuntu virtual machine
2. Look at the system logs
3. Deploy the application in Docker
4. See the application event log
5. Write the first Sigma rule
6. Carry out an attack and detect it
7. Remove a false positive
+ Detect enumeration of other people’s orders

Lab diagram



User and attacker actions → log → rules → alerts

TraceShop LAB: four tasks in the browser

01 · Guessing
5 failures for `anna`, then a successful login

02 · Spraying
1 password, 8 different logins, 1 IP address

03 · Order enumeration
start at 1001 and accumulate 5 denials

04 · Disabling MFA
leave the ticket empty and create a critical event

> The order is fixed: each task unlocks the next, and progress matches the Sigma thresholds

ПРАКТИКА 3 · RED TEAM → BLUE TEAM

Взломайте учебный магазин.

Затем поймайте себя по журналу.

Все действия настоящие: запросы уходят в приложение, а события появляются справа в реальном времени. Выполняйте миссии строго слева направо — следующая откроется после предыдущей.

ПЕРЕХВАЧЕННАЯ ЗАМЕТКА

Покупатель anna любит цветы. В конце пароля — одна цифра.

Номера заказов последовательны и начинаются с 1001.

Адрес исследователя 203.0.113.77

01 Получить доступ как anna
0/5 неудач, затем успех

02 Создать распыление
заблокировано

03 Найти чужие заказы
заблокировано

04 Отключить MFA без заявки
заблокировано

АТАКУЮЩАЯ СТОРОНА

РУЧНОЙ РЕЖИМ

Рабочая консоль

ЗАЩИТНАЯ СТОРОНА

ОБНОВЛЕНИЕ 2 СЕК

Живая телеметрия

Task 01 · gain access as anna

First create the trace
5 wrong passwords
for `anna`

→

Then log in
the correct password
`sunflower7`

> A success before five failures does not complete the task: the “failures → login” sequence matters

T TraceShop LAB

журнал активен | Сбросить стенд

01 Получить доступ как anna
выполнено ✓

02 Создать распыление
0/8 разных логинов

03 Найти чужие заказы
заблокировано

04 Отключить MFA без заявки
заблокировано

АТАКУЮЩАЯ СТОРОНА

РУЧНОЙ РЕЖИМ

Рабочая консоль

01 Подбор пароля

Проверяйте гипотезы по одной и следите за событиями.

УЧЁТНАЯ ЗАПИСЬ: anna

ПАРОЛЬ: sunflower7

123456 | qwerty | anna2026 | sunflower | letmein

Попробовать войти

МИССИЯ ВЫПОЛНЕНА · доступ как anna

02 Распыление пароля

Один пароль, разные логины, один адрес.

ОДИН ПАРОЛЬ: 123456

СЛЕДУЮЩАЯ УЧЁТНАЯ ЗАПИСЬ: clara

АДРЕС ИСТОЧНИКА: 198.51.100.23

Отправить попытку

Нужно 8 разных логинов

ЗАЩИТНАЯ СТОРОНА

ОБНОВЛЕНИЕ 2 СЕК

Живая телеметрия

6	5	0
событий	ошибок входа	отказов доступа

НАБЛЮДЕНИЕ

anna: 5 неудач

Последние события — обновить

auth.login · success 12:39:23
actor=anna source=203.0.113.77

auth.login · failure 12:39:22
actor=anna source=203.0.113.77

auth.login · failure 12:39:22
actor=anna source=203.0.113.77

auth.login · failure 12:39:22
actor=anna source=203.0.113.77

auth.login · failure 12:39:22
actor=anna source=203.0.113.77

Task 02 · create a spraying pattern

1 · One password

`123456` stays the same

2 · Different logins

eight different accounts

3 · One address

`198.51.100.23` links the attempts

> Grouping by address reveals a campaign made of many quiet attempts

01 Получить доступ как anna
выполнено ✓

02 Создать распыление
выполнено ✓

03 Найти чужие заказы
0/5 отказов

04 Отключить MFA без заявки
заблокировано

АТАКУЮЩАЯ СТОРОНА

РУЧНОЙ РЕЖИМ

Рабочая консоль

01 Подбор пароля

Проверяйте гипотезы по одной и следите за событиями.

УЧЁТНАЯ ЗАПИСЬ: anna

ПАРОЛЬ: sunflower7

123456 qwerty anna2026 sunflower letmein

Попробовать войти

МИССИЯ ВЫПОЛНЕНА · доступ как anna

02 Распыление пароля

Один пароль, разные логины, один адрес.

ОДИН ПАРОЛЬ: 123456

СЛЕДУЮЩАЯ УЧЁТНАЯ ЗАПИСЬ: kirill

АДРЕС ИСТОЧНИКА: 198.51.100.23

Отправить попытку

Попытка записана · kirill · 8/8 разных логинов

ЗАЩИТНАЯ СТОРОНА

ОБНОВЛЕНИЕ 2 СЕК

Живая телеметрия

14	13	0
событий	ошибок входа	отказов доступа

НАБЛЮДЕНИЕ

anna: 5 неудач · распыление: 198.51.100.23

Последние события — обновить

```
auth.login · failure 12:39:25
actor=kirill source=198.51.100.23

auth.login · failure 12:39:25
actor=julia source=198.51.100.23

auth.login · failure 12:39:24
actor=igor source=198.51.100.23

auth.login · failure 12:39:24
actor=galina source=198.51.100.23

auth.login · failure 12:39:24
actor=frank source=198.51.100.23
```

Task 03 · find other people’s orders

Own orders

1001–1002 belong to `anna` — `data.read · success`

Other people’s orders

1003–1007 belong to others — `authz.access · failure`, reason `not_owner`

Goal

accumulate 5 denials by enumerating numbers

> The log records who accessed which object and why it was denied

123456 qwerty anna2026 sunflower letmein

Попробовать войти

МИССИЯ ВЫПОЛНЕНА · доступ как anna

02 Распыление пароля

Один пароль, разные логины, один адрес.

ОДИН ПАРОЛЬ: 123456

СЛЕДУЮЩАЯ УЧЁТНАЯ ЗАПИСЬ: kirill

АДРЕС ИСТОЧНИКА: 198.51.100.23

Отправить попытку

Попытка записана · kirill · 8/8 разных логинов

03 Перебор заказов

Проверяйте соседние ID.

ДЕЙСТВОВАТЬ КАК: anna

НОМЕР ЗАКАЗА: 1007

Открыть заказ

403 · not_owner · отказов 5/5

04 Отключение MFA

Оставьте заявку пустой.

ДЕЙСТВОВАТЬ КАК: anna

ID ЗАЯВКИ (НЕОБЯЗАТЕЛЬНО): например, SEC-42

Отключить MFA

Повторный пароль не требуется

anna: 5 неудач · распыление: 198.51.100.23 · отказы anna: 5

Последние события

обновить

authz.access · failure 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

data.read · success 12:39:26
actor=anna source=203.0.113.77

data.read · success 12:39:26
actor=anna source=203.0.113.77

auth.login · failure 12:39:25
actor=kirill source=198.51.100.23

auth.login · failure 12:39:25
actor=julia source=198.51.100.23

auth.login · failure 12:39:24
actor=igor source=198.51.100.23

Task 04 · disable MFA

Vulnerability

the second factor is disabled without re-entering the password

Trace in the log

`auth.mfa.disable` without a `ticket_id` field

Severity

a `high` level event — a critical action

All four tasks are done — the whole attack chain is visible in the log

123456 qwerty anna2026 sunflower letmein

Попробовать войти

МИССИЯ ВЫПОЛНЕНА · доступ как anna

02 Распыление пароля

Один пароль, разные логины, один адрес.

ОДИН ПАРОЛЬ: 123456

СЛЕДУЮЩАЯ УЧЁТНАЯ ЗАПИСЬ: kirill

АДРЕС ИСТОЧНИКА: 198.51.100.23

Отправить попытку

Попытка записана · kirill · 8/8 разных логинов

03 Перебор заказов

Проверяйте соседние ID.

ДЕЙСТВОВАТЬ КАК: anna

НОМЕР ЗАКАЗА: 1007

Открыть заказ

403 · not_owner · отказов 5/5

04 Отключение MFA

Оставьте заявку пустой.

ДЕЙСТВОВАТЬ КАК: anna

ID ЗАЯВКИ (НЕОБЯЗАТЕЛЬНО): например, SEC-42

Отключить MFA

MFA отключён · anna

заявки: 1

Последние события

обновить

auth.mfa.disable · success 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

data.read · success 12:39:26
actor=anna source=203.0.113.77

data.read · success 12:39:26
actor=anna source=203.0.113.77

auth.login · failure 12:39:25
actor=kirill source=198.51.100.23

auth.login · failure 12:39:25
actor=julia source=198.51.100.23

A log event answers questions

What happened?	`"event_type": "auth.login"`
With what result?	`"outcome": "failure"`
Who?	`"actor": {"id": "anna"}`
From where?	`"source_ip": "203.0.113.77"`
Details?	`"context": {"reason": "bad_password"}`

A common format → one rule finds all such events

A rule is a condition over log records

Base rules that the correlations refer to (`00_base.yml`):

```yaml
title: Failed login
name: failed_login
logsource: {product: shop-app, service: auth}
detection:
    selection: {event_type: auth.login, outcome: failure}
    condition: selection
---
title: Successful login
name: successful_login
detection:
    selection: {event_type: auth.login, outcome: success}
    condition: selection
```

Rule: password guessing

```yaml
title: Password guessing against an account
correlation:
    type: event_count
    rules: [failed_login]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 5}
```

event_count count events

group-by per account

condition 5 or more failures in 10 minutes

Rule: password spraying

```
title: Password spraying from one address
correlation:
    type: value_count
    rules: [failed_login]
    group-by: [source_ip]
    timespan: 30m
    condition: {field: actor.id, gte: 8}
```

value_count count DISTINCT values

group-by per source address

condition 8 or more distinct accounts

Rule: login after a series of failures

```yaml
title: Successful login after a series of failures
correlation:
    type: temporal_ordered
    rules: [failed_login_burst, successful_login]
    group-by: [actor.id]
    timespan: 15m
---
name: failed_login_burst
correlation:
    type: event_count
    rules: [failed_login]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 3}
```

`temporal_ordered` events in a given order

first a series of failures, then a successful login

Run: `python3 detect.py --events ../app/logs/events.jsonl --rules rules`

Extra task

Attack
an attacker acting as `anna`
enumerates other people’s orders

→

Trace
`authz.access`
`outcome: failure`

> Write an `event_count` rule by `actor.id` for access denials. How many denials does `anna` have?

Extra task solution

```yaml
title: Enumeration of other people's objects
name: object_enumeration
detection:
    selection:
        event_type: authz.access
        outcome: failure
    condition: selection
---
title: Series of access denials
correlation:
    type: event_count
    rules: [object_enumeration]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 5}
```

1 alert

account `anna`

7 access denials

Methods and Principles of Designing Modern Secure Systems

Practice 3

Detecting Attacks from the Event Log

Interactive practice · a browser attack, a live log, Sigma rules